

Section A: Short-Answer Questions (10 questions)

1. Define governance, risk, and compliance, and explain why they must be managed together in modern organizations.

Governance refers to the decision-making structures and processes that direct an organization. *Risk management* focuses on identifying and addressing uncertainties that affect objectives. *Compliance* ensures adherence to laws, regulations, and standards. These concepts must be managed together because failures in one area (e.g., governance) can lead to failures in others (e.g., compliance) due to the interconnected nature of modern risks.

2. Explain what is meant by the statement that modern GRC is shifting from control checking to strategic resilience.

Traditional GRC focused on whether controls existed. Modern GRC emphasizes whether organizations can adapt to changes, respond to disruptions, and maintain trust under evolving conditions.

3. Identify three ways in which the current risk environment is faster than the traditional risk environment.

- Cyberattacks can spread within hours.
- Service outages can cascade through global systems.
- Misinformation can instantly impact public trust and reputation.

4. Distinguish between third-party risk and ecosystem dependency risk.

Third-party risk focuses on the direct risks of engaging external vendors. Ecosystem dependency risk highlights broader reliance on shared infrastructures (e.g., cloud platforms), where failures impact multiple services simultaneously.

5. State two reasons why AI has become a major topic in governance, risk, and compliance.

- AI introduces biases, privacy violations, and security risks.
- AI changes governance by requiring oversight of both the systems and their outputs.

6. Explain the meaning of risk-based accountability in AI governance.

Risk-based accountability ensures AI systems are governed in proportion to their potential harm. High-risk systems face stricter governance requirements, such as documentation, testing, and human oversight.

7. Why is resilience now considered a core GRC outcome rather than only a technical or operational issue?

Resilience is about anticipating and responding to disruptions while maintaining critical functions, which requires cross-functional collaboration and governance, not just technical fixes.

8. What is continuous compliance, and why are periodic review cycles often insufficient today?

Continuous compliance involves ongoing monitoring and response to regulatory changes. Periodic reviews are insufficient because regulations and risks evolve quickly, requiring continuous adjustment.

9. Explain the importance of shared taxonomies in integrated GRC.

Shared taxonomies enable consistent definitions, reporting, and connections between risks, controls, and incidents, improving decision-making and reducing fragmentation.

10. **Why can culture and capability be described as control issues in their own right?**
Poor culture discourages escalation of risks, and lack of capability leads to ineffective implementation of controls, making them central to governance quality.

Section B: Essay and Discussion Questions (10 questions)

11. **Discuss the major forces driving change in modern GRC.**
Forces include digital transformation, cyber threats, AI, third-party dependencies, regulatory changes, and public scrutiny. These forces are interconnected; for example, AI governance requires addressing cybersecurity and regulatory compliance simultaneously.
12. **Critically examine the argument that AI is both a business accelerator and a new risk domain.**
AI accelerates business by improving efficiency (e.g., fraud detection, automation). However, it also introduces risks like bias, privacy violations, and security vulnerabilities, which require governance frameworks like the NIST AI Risk Management Framework.
13. **Assess the view that a compliant organization is not always a resilient organization.**
Compliance ensures adherence to rules but does not guarantee the ability to respond to disruptions. A resilient organization plans for continuity, absorbs shocks, and recovers effectively, going beyond compliance.
14. **Explain how integrated GRC improves governance quality compared with siloed models.**
Integrated GRC connects risks, controls, and evidence across functions, enabling faster decisions and better traceability. However, poor design or weak data quality can limit its effectiveness.
15. **Using a practical example, demonstrate how one disruption can trigger governance, risk, and compliance failures at the same time.**
Example: A ransomware attack can expose data (compliance failure), disrupt operations (risk failure), and highlight governance issues (e.g., lack of escalation processes).
16. **Analyze how third-party risk has evolved into ecosystem dependency risk.**
Organizations now rely on shared infrastructures, making them vulnerable to systemic failures (e.g., a cloud provider outage disrupting multiple services).
17. **Discuss the role of resilience testing in modern GRC.**
Resilience testing ensures that critical services can recover during disruptions, highlighting weak points and improving preparation for real-world scenarios.
18. **Evaluate the significance of ethical leadership in GRC.**
Ethical leadership promotes transparency, accountability, and trust, ensuring that governance structures function effectively and align with organizational values.
19. **Explain the relationship between regulatory change and continuous compliance.**
Regulatory change requires organizations to monitor developments, update policies, and maintain evidence continuously, as static approaches cannot keep pace with evolving expectations.
20. **Discuss the implications of culture and capability gaps for GRC professionals.**
Gaps in culture and capability weaken risk recognition, incident response, and compliance. Professionals must foster psychological safety and build cross-disciplinary skills to address these issues.

Section C: Applied Case Questions (10 questions)

Scenario: A digital bank relies on a third-party AI service to support customer onboarding and service requests. During a major outage, the platform becomes unavailable, customer data are exposed, and some automated responses are found to be inaccurate and misleading.

21. Identify the GRC issues triggered by this disruption.

- Governance: Lack of oversight in selecting/approving the AI system.
- Risk: Dependency on the third-party platform and failure to assess its risks.
- Compliance: Data exposure violates privacy regulations.

22. What steps should the bank take to address the disruption in real time?

- Activate incident response plans.
- Notify regulators and affected customers.
- Investigate and mitigate the root cause.
- Escalate issues to leadership for coordinated action.

23. How could better third-party risk management have prevented this issue?

Improved vendor assessments, dependency mapping, and resilience testing could have identified platform weaknesses and mitigated potential disruptions.

24. What role does resilience play in ensuring the bank's long-term recovery?

Resilience ensures the bank can restore critical services, maintain customer trust, and prevent similar issues through improved planning and testing.

25. What lessons can be learned about integrated GRC from this incident?

Integrated GRC could have connected AI risks, third-party dependencies, and compliance obligations, enabling proactive management and faster response.

26. How should the bank's culture and capability be improved to prevent future incidents?

The bank must foster a culture that prioritizes transparency in risk reporting and build capabilities in AI oversight, third-party risk management, and resilience planning.

27. What specific AI governance practices should the bank implement?

- Maintain an inventory of AI use cases.
- Classify AI systems by risk level.
- Establish validation, testing, and monitoring processes.
- Document governance and approval workflows.

28. How does this incident demonstrate the interconnectedness of GRC issues?

The outage affected governance (approval processes), risk (dependency on a single vendor), and compliance (data exposure), showing the need for integrated management.

29. What is the importance of evidence in addressing regulatory and compliance challenges arising from this incident?

Evidence (e.g., incident logs, vendor agreements) demonstrates the bank's efforts to comply with regulations and mitigate risks, which is critical for accountability.

30. What long-term changes should the bank make to its GRC strategy?

- Shift from periodic reviews to continuous compliance.
- Strengthen vendor segmentation and monitoring.
- Conduct regular resilience testing.

- Implement integrated GRC tools for better visibility and coordination.

MCQs on Governance, Risk, and Compliance (GRC)

1-10: Foundational Concepts in GRC

1. **What does GRC stand for?**

- a) Governance, Regulation, and Compliance
- b) Governance, Risk, and Compliance
- c) Governance, Risk, and Cybersecurity
- d) Governance, Risk, and Control

Answer: b) Governance, Risk, and Compliance

2. **What is the primary focus of governance in GRC?**

- a) Identifying risks
- b) Ensuring adherence to laws
- c) Directing and controlling an organization
- d) Conducting audits

Answer: c) Directing and controlling an organization

3. **Why is GRC becoming more integrated?**

- a) To reduce costs associated with compliance
- b) To address fragmented approaches to risk and compliance
- c) To replace traditional control checklists
- d) To automate all governance processes

Answer: b) To address fragmented approaches to risk and compliance

4. **What is a key difference between traditional and modern GRC?**

- a) Traditional GRC focuses on operational resilience, while modern GRC focuses on document control.
- b) Traditional GRC focuses on control existence, while modern GRC focuses on decision quality and resilience.
- c) Traditional GRC is more strategic than modern GRC.
- d) Traditional GRC emphasizes cultural change, while modern GRC does not.

Answer: b) Traditional GRC focuses on control existence, while modern GRC focuses on decision quality and resilience.

5. **Which of the following is NOT a feature of modern GRC?**

- a) Continuous oversight
- b) Evidence-based accountability
- c) Siloed governance structures
- d) Operational resilience

Answer: c) Siloed governance structures

6. **What is meant by "evidence-based accountability"?**

- a) Collecting evidence for compliance breaches
- b) Proving systems, decisions, and operations remain acceptable under changing conditions
- c) Documenting internal policies
- d) Ensuring periodic audits are conducted

Answer: b) Proving systems, decisions, and operations remain acceptable under changing conditions

7. Why has GRC shifted to a more strategic discipline?

- a) To eliminate third-party risks
- b) Because the modern risk environment is faster, wider, and more interconnected
- c) To focus solely on internal fraud and financial controls
- d) To reduce the need for compliance activities

Answer: b) Because the modern risk environment is faster, wider, and more interconnected

8. Which of the following is an example of a modern risk that organizations face?

- a) Internal fraud
- b) Talent shortages
- c) Financial mismanagement
- d) Periodic audit gaps

Answer: b) Talent shortages

9. What has contributed to the faster pace of modern risks?

- a) Static regulatory environments
- b) Limited dependency on external providers
- c) Cyberattacks and misinformation spreading quickly
- d) Reduced public scrutiny

Answer: c) Cyberattacks and misinformation spreading quickly

10. What is the primary goal of integrated GRC?

- a) To establish siloed workflows for easier management
- b) To connect risks, controls, and evidence across functions
- c) To limit the scope of risk management
- d) To focus solely on regulatory compliance

Answer: b) To connect risks, controls, and evidence across functions

11-20: Emerging Trends in GRC

11. Which trend has the strongest influence on modern GRC?

- a) Talent acquisition
- b) Regulatory leniency
- c) Rapid digital transformation
- d) Single-system dependency

Answer: c) Rapid digital transformation

12. What is the dual role of AI in GRC?

- a) AI is used for governance but not for compliance.
- b) AI is both a technical innovation and a compliance burden.
- c) AI is a business accelerator and a new risk domain.
- d) AI is only relevant to technology-driven organizations.

Answer: c) AI is a business accelerator and a new risk domain.

13. What is a key requirement for AI governance under the EU AI Act?

- a) Eliminating bias completely
- b) Proving the accuracy of outputs only
- c) Classifying AI systems by risk level and imposing stronger obligations on higher-risk systems
- d) Allowing unrestricted AI deployment

Answer: c) Classifying AI systems by risk level and imposing stronger obligations on higher-risk systems

14. What does risk-based accountability in AI governance mean?

- a) Governing AI based on its potential financial benefits
- b) Governing AI proportionate to its potential harm
- c) Governing AI only for high-risk industries
- d) Eliminating accountability in low-risk AI systems

Answer: b) Governing AI proportionate to its potential harm

15. What is the focus of resilience in modern GRC?

- a) Avoiding all operational disruptions
- b) Ensuring critical operations continue during disruptions and recover quickly
- c) Replacing compliance as a priority
- d) Documenting policies for disaster recovery

Answer: b) Ensuring critical operations continue during disruptions and recover quickly

16. What is ecosystem dependency risk?

- a) Overreliance on internal business processes
- b) Dependency on external infrastructures that affect multiple services
- c) Avoidance of third-party risk management
- d) Reducing reliance on shared infrastructures

Answer: b) Dependency on external infrastructures that affect multiple services

17. What is the focus of continuous compliance?

- a) Periodic regulatory reviews
- b) Reacting to compliance issues after they occur
- c) Ongoing monitoring and adaptation to regulatory changes
- d) Limiting compliance scope to internal operations

Answer: c) Ongoing monitoring and adaptation to regulatory changes

18. Why are shared taxonomies critical in integrated GRC?

- a) They reduce compliance costs significantly.
- b) They connect risks, controls, and incidents across the organization.
- c) They eliminate the need for periodic reviews.
- d) They simplify the approval process for AI systems.

Answer: b) They connect risks, controls, and incidents across the organization.

19. Which of the following is a key feature of third-party risk management?

- a) Ignoring fourth-party dependencies
- b) Using static vendor questionnaires
- c) Conducting vendor segmentation and dependency mapping
- d) Avoiding ecosystem dependency risks

Answer: c) Conducting vendor segmentation and dependency mapping

20. What is the relationship between culture and GRC?

- a) Culture has no significant influence on GRC.
- b) Weak culture can lead to poor risk recognition and escalation of issues.
- c) Culture simplifies operational resilience testing.
- d) Culture replaces the need for compliance frameworks.

Answer: b) Weak culture can lead to poor risk recognition and escalation of issues.

21-30: Application and Scenario-Based Questions

21. **Which of the following disruptions could activate multiple GRC concerns?**
- a) A routine internal audit
 - b) A third-party outage exposing customer data
 - c) A minor software update
 - d) A compliance team meeting
- Answer: b) A third-party outage exposing customer data**
22. **What makes AI governance a challenge?**
- a) AI systems do not require validation.
 - b) AI systems can produce biased and opaque outputs.
 - c) AI systems are fully transparent.
 - d) AI systems cannot affect compliance.
- Answer: b) AI systems can produce biased and opaque outputs.**
23. **What is a compliant organization?**
- a) One that focuses only on controls and policies
 - b) One that is capable of anticipating and absorbing disruptions
 - c) One that follows laws and regulations but may lack resilience
 - d) One that eliminates all risks
- Answer: c) One that follows laws and regulations but may lack resilience**
24. **What is a resilient organization?**
- a) One that avoids all risks
 - b) One that anticipates and absorbs disruptions while continuing critical operations
 - c) One that focuses solely on compliance
 - d) One that depends on external providers for recovery
- Answer: b) One that anticipates and absorbs disruptions while continuing critical operations**
25. **What is the ultimate goal of integrated GRC?**
- a) Simplifying compliance audits
 - b) Achieving effective governance, risk, and compliance across the organization
 - c) Eliminating all external dependencies
 - d) Conducting periodic reviews
- Answer: b) Achieving effective governance, risk, and compliance across the organization**
26. **Which of the following is a feature of AI risk management frameworks like NIST?**
- a) Ignoring impacts on individuals
 - b) Addressing trustworthiness throughout the AI lifecycle
 - c) Limiting oversight to high-risk AI systems only
 - d) Eliminating documentation requirements for AI systems
- Answer: b) Addressing trustworthiness throughout the AI lifecycle**
27. **What is an example of concentration risk?**
- a) Relying on a single cloud provider for multiple services
 - b) Diversifying vendor dependencies
 - c) Using redundant systems for resilience
 - d) Outsourcing only non-critical services
- Answer: a) Relying on a single cloud provider for multiple services**
28. **What is a key limitation of siloed governance?**
- a) It simplifies reporting to leadership.
 - b) It prevents coordination between functions.

- c) It strengthens issue management.
- d) It connects risks and controls effectively.

Answer: b) It prevents coordination between functions.

29. What is the purpose of resilience testing?

- a) To identify cultural gaps in organizations
- b) To assess whether critical services can recover during disruptions
- c) To reduce compliance obligations
- d) To avoid vendor segmentation

Answer: b) To assess whether critical services can recover during disruptions

30. What should students focus on to excel in GRC?

- a) Policy interpretation only
- b) Developing technological literacy and analytical thinking
- c) Limiting focus to compliance tasks
- d) Avoiding cross-disciplinary skills

Answer: b) Developing technological literacy and analytical thinking